

DATA RETENTION UNDER

DPDPA

&

OTHER INDIAN LAWS

The Digital Personal Data Protection Act, 2023 (DPDPA) marks a pivotal moment in India's data governance regime, introducing a unified legal framework for the processing of digital personal data. Mirroring global standards such as the GDPR and HIPAA, the DPDPA enshrines the principles of data minimisation and storage limitation, mandating that data fiduciaries collect only the data necessary for a defined purpose and erase it once that purpose is fulfilled.

This represents a significant departure from India's legacy approach, where sectoral laws—across **HEALTHCARE, FINANCE, LABOUR, AND IT**—mandated minimum retention periods but lacked clarity on maximum retention durations or consequences of indefinite storage. As a result, entities have historically engaged in excessive data retention, often retaining personal data well beyond operational or legal necessity.

The widespread data hoarding mindset has led to large-scale accumulation of digital information. This has legal and operational risks. Retained personal data, even when no longer required, becomes a liability in the context of data breaches, litigation, and regulatory non-compliance.

The DPDPA's data erasure mandate, introduced without a direct Indian legislative predecessor, presents a novel compliance challenge. It requires organizations to fundamentally rethink data retention practices and implement structured data lifecycle management protocols.

In effect, the Act shifts the paradigm from data maximization to data responsibility, placing privacy and accountability at the centre of digital data governance in India.

Most laws are silent on the consequences of indefinite retention of personal data, leaving room for over-collection and excessive storage.

These regulations were generally crafted without adequate consideration of privacy concerns or the evolving concept of data protection. As a result, individuals' personal data is often retained indefinitely, posing risks to privacy, security, and misuse.

But here's the challenge:

In our fast-moving digital economy, businesses generate and store data at unprecedented speeds—across laptops, phones, cloud platforms, and more. While sectoral regulations may already require data retention, most of this data includes personal identifiers (name, age, contact details, etc.), bringing it under the DPDPA's scope.

 Holding on to unnecessary data isn't just a storage issue—it's a liability. Indefinite data retention increases the risk of legal exposure, especially in litigation or data breaches. And with DPDPA's data erasure mandate, ignoring these risks is no longer an option.

PRESERVATION OF RECORDS UNDER THE EXISTING LAWS

Act/Regulations	Period of retention	Person Liable
Indian Medical Council (Professional Conduct, Etiquette and Ethics) Regulations, 2002	Medical record of patients for 3 years	Medical Practitioners
New Drugs and Clinical Trials Rules, 2019	Record for 5 years	Biotech entities
Income Tax Law	6 years from the end of the relevant assessment year	Professionals providing services u/s 44AA(3)
Income Tax Law Rule 10D of the Income Tax Rules	8 years from the end of the relevant assessment year	Person who has entered into an international transaction or a specified domestic transaction
Goods and Services Tax	6 years	Company/Assesse
Records retention under VAT & Service tax time period varies state wise from 5 to 8 years.		
Companies Act 2013	8 financial years immediately preceding a financial year	Any entity registered under Companies Act
	Prior permission of the Central Government to dispose records	Any merged/ amalgamated entity
	Dissolved company for a period of 5 years from the date of its dissolution	Directors/ Majority Shareholder/Owner
Mimumum Wages Act 1948	3 financial years immediately preceding a financial year	Any entity registered under Minimum Wages Act
ESI ACT, PF Act & other Labour Laws	5 financial years immediately preceding a financial year	Any entity registered under the respective Act
SEBI Guidelines Regulation 18 of SEBI (Stock Brokers & Sub- brokers) Regulations	Minimum 5 years	Every stock broker
Regulation 15 of the SEBI (Registrars to an Issue and Share Transfer Agents)	Minimum 3 years	Every RTA & STA
SEBI (Mutual Funds) Regulations	Minimum 8 years	Every Asset Management Company
Prevention of Money-Laundering Act as per notified rules	Minimum 10 years	Every financial, banking or NBFC Entity

DATA RETENTION POLICIES & ITS DOCUMENTATION

A Data retention policy provides for the systematic review, retention and destruction of documents received or created in the course of business. A retention policy will identify documents that need to be maintained and contain guidelines for how long certain documents should be kept and how they should be destroyed.

A documented retention policy is only as good as its implementation. A policy needs to be rigorously enforced from top management down. Companies must make sure educate their employees about not only the policy, but the implication of not following it. It must be easy to follow, periodically renewed, and it must clearly lay out how often it will be audited. The policy should also address the fact that employees may store and save information in different ways (i.e., some employees may save documents to a hard drive, others to a network) and on different hardware (some emails are only saved on devices and not in desktop or laptop inboxes). In addition, the policy must be flexible enough to be suspended if a litigation hold is necessary. The policy should address the litigation hold and how it is to be implemented, including any policy on email backup tapes.

The DPDPA's privacy framework is *entirely new*, with no direct Indian precedent. This makes compliance a cultural and operational shift for many entities—one that requires rethinking long-held habits around digital storage.

It's time for organizations to move from *data hoarding* to *data responsibility*. Proactive data lifecycle management isn't just good governance—it's now a legal requirement.

HOW LONG CAN YOU RETAIN PERSONAL DATA?

Unlike sectoral laws—such as those in finance, healthcare, labour, or IT—which often mandate *minimum data retention periods* (e.g., 5–8 years for tax or employment records), the DPDPA is agnostic to sector and focused on **purpose**.

Under DPDPA, the key principles are:

✓ **Data Minimisation** – Collect only what is necessary

✓ **Storage Limitation** – Retain personal data **only until the purpose is fulfilled**, then erase

This is inspired by global standards like the **GDPR** and **HIPAA**, and applies **universally** to all entities processing personal data—including those already regulated under sector-specific laws.

The Challenge:

In today's digital environment, organizations accumulate data rapidly—across servers, phones, laptops, and cloud systems. Most of this data includes **personal identifiers** (name, age, contact details), bringing it squarely under the DPDPA.

 Retaining such data indefinitely is no longer just a storage concern—it becomes a **compliance risk**. Data that has outlived its purpose must be **erased**. Continuing to hold it could expose organizations to liabilities during breaches, audits, or litigation.

So, which law prevails?

- **Follow sectoral laws for minimum retention** (e.g., tax, regulatory, employment obligations)
- **Apply DPDPA's erasure obligation once the purpose or legal requirement is met**

Think of DPDPA as the **baseline privacy framework**—where personal data must not be held *longer than necessary*, even if sectoral rules are silent.

 The takeaway:

Move from data hoarding to data accountability.
The cost of over-retention is no longer theoretical—it's regulatory.